

SEC-PROC-PATCH-001 V2 - Plant Patch and Vulnerability Management Standard (APPROVED)

Synthetic training document. Not for operational use.

Document ID: SEC-PROC-PATCH-001 | Version 2.0 | Status: APPROVED | Effective: 2025-06-01 | Owner: Plant Cyber Security | Approver: Head of Engineering and CISO delegate

1. Purpose

Defines remediation targets and handling rules for vulnerabilities on plant assets, condition-monitoring gateways and engineering workstations.

2. Severity and remediation targets

Severity follows the CVSS-style base score recorded on the vulnerability register.

Severity	Score range	Remediate within
Critical	9.0 - 10.0	7 days
High	7.0 - 8.9	14 days
Medium	4.0 - 6.9	30 days
Low	0.1 - 3.9	90 days

The clock starts on the found date. An open item past its target is OVERDUE and must be escalated.

3. Operational technology rules

- 1 A patch on a plant-connected asset is never applied during operation. It needs an approved maintenance window and a sign-off from the responsible engineering owner.
- 2 If a patch cannot be applied inside the target, a compensating control (for example network isolation or disabling the affected service) must be recorded and the item moves to ACCEPTED RISK only with written approval from the Head of Engineering.
- 3 Condition-monitoring gateways that are Restricted or External exposure are reviewed first.

4. Escalation

Overdue High or Critical items on an asset with Critical or High criticality are reported to the Plant Cyber Security lead within 2 working days, together with the current operational health status of the asset so engineering can plan the window.

5. Limits

This standard does not authorise anyone to apply a patch, change a configuration or close a security item. A qualified human owner decides and records the outcome.